Application – specific access policies using Zscaler Private Access

Project Title:

Application – specific access policies using Zscaler Private Access

Program: Naan Mudhalvan

Course : Cyber Security

Team Members:

Member 1 – Arjun & 2328c0226

Member 2 – Aththin Ameena & 2328c0227

Member 3 – Pavithra & 2328c0228

Member 4 – Thanushree & 2328c0229

Member 5 -Srimathi & 2328c0001

Institution : Cheran Arts Science College

Guide :Mrs.M.Jeevitha

Date :09.03.2026

Abstract:

With the rapid adoption of cloud computing and remote work environments, organizations face increasing challenges in securing internal applications while ensuring seamless user access. Traditional network security models, such as VPN-based access, often provide broad network connectivity, which can increase the risk of unauthorized access and lateral movement within the network. To address these challenges, modern security frameworks adopt a Zero Trust approach, where access is granted only to specific applications based on user identity, device posture, and contextual policies. Zscaler Private Access (ZPA) is a cloud-based Zero Trust Network Access (ZTNA) solution that enables secure, application-level access without exposing the internal network to the internet.

This project focuses on implementing application-specific access policies using Zscaler Private Access to enhance enterprise security. The objective is to design and configure fine-grained access control policies that allow users to access only the applications they are authorized to use, rather than granting full network access. By leveraging identity-based authentication, policy enforcement, and segmentation, ZPA ensures that each user receives least-privileged access to enterprise applications.

The system architecture involves integrating ZPA with enterprise identity providers, application connectors, and user devices to create a secure communication path between users and internal applications. Application segments and access policies are defined within the ZPA administrative portal, enabling administrators to control access based on roles, departments, and security requirements. This approach minimizes attack surfaces, prevents unauthorized access, and enhances visibility into application usage.

The implementation demonstrates how organizations can replace traditional VPN solutions with a Zero Trust model that improves both security and scalability. Key features of the system include secure application segmentation, policy-based access control, encrypted connections, and centralized management through the ZPA cloud platform. Testing and evaluation show that application-specific access

policies significantly reduce security risks while maintaining efficient and seamless access for authorized users.

In conclusion, this project highlights the effectiveness of Zero Trust security using Zscaler Private Access in protecting enterprise applications. By implementing application-specific access policies, organizations can strengthen their security posture, reduce network exposure, and support modern remote work environments with secure and controlled access to internal resources.

Use Case Scenarios

Scenario 1.Third-Party Vendor Access (Jit/Contractor)

In this scenario, you have a contractor who only needs to access a specific Jira instance or a staging web server for a limited time.

•Policy Logic: Access is granted based on the user group "Contractors" AND the specific application "Staging-Web-01."

•Security Control: You can restrict access to specific ports (e.g., only TCP 443) and set an Access Policy Timeout so the session expires after 8 hours, requiring re-authentication.

Scenario 2. Secure DevOps & Server Management (SSH/RDP)

Instead of opening RDP or SSH ports to the entire internal subnet, you can create policies that target specific administrative protocols for specific servers.

•Policy Logic: Only members of the "IT Admin" group can initiate an SSH session to the "Production Database" application segment.

•Security Control: You can enable AppProtection to inspect the traffic for command injection or utilize Privileged Remote Access (PRA) to provide browser-based access without needing a local client.

Scenario 3. Posture-Based Access (Managed vs. Unmanaged)

You can differentiate access based on the "health" or "ownership" of the device. This is crucial for preventing data leaks from infected or personal machines.

- Policy Logic: * Managed Laptop: Full access to the "Internal ERP System."
- Personal/BYOD Device: Access is blocked, or redirected to a restricted web-only version.
- Security Control: ZPA checks for a specific Posture Profile (e.g., Is the firewall on? Is a corporate cert present?) before the tunnel is established.

Scenario 4. Geographic or Location-Aware Access

If your company has strict compliance requirements (like GDPR or ITAR), you may want to ensure that certain sensitive applications are only accessed from specific regions.

- Policy Logic: Access to "Sensitive-HR-Database" is only permitted if the user’s Country is "United Kingdom" or "Germany."
- Security Control: If a user attempts to log in from a restricted country, the ZPA Broker (App Connector) will deny the connection at the edge, even if the credentials are valid.

Scenario 5. Emergency "Break-Glass" Access

In the event of a localized outage or a specific security incident, you can have pre-configured policies that are normally disabled but can be toggled to provide emergency access.

- Policy Logic: High-privilege access to "Core Infrastructure" triggered only when a specific "Emergency-Response" SAML attribute is present in the user's token.

- Security Control: This uses Conditional Access to ensure that even "Admins" don't have permanent, standing access to the most sensitive parts of the environment.

STAGE – 1

Title of the project :

Application – specific access policies using Zscaler Private Access

List of vulnerability :

ZPA Vulnerability & Risk Table

Vulnerability Type Risk / CVE ID Description Impact Mitigation Strategy

Configuration Implicit "Allow All" Policy order allows broad access before reaching specific blocks. Lateral movement across the network. Use Top-Down logic; ensure the last rule is an "Implicit Deny."

Configuration Over-Privileged Service Accounts Shared accounts or broad groups (e.g., "All Staff") assigned to sensitive apps. Unauthorized data access by standard users. Map specific AD Groups to specific App Segments (Least Privilege).

Software (ZCC) CVE-2025-54983 Health check port on Zscaler Client Connector (Windows) allows traffic bypass. Traffic bypasses ZCC forwarding controls. Upgrade ZCC to versions 4.6.0.216+ or 4.7.0.47+.

Software (ZCC) CVE-2024-31127 Improper library verification in ZCC (macOS) allows privilege escalation. Local attacker gains root/admin privileges. Upgrade macOS ZCC to version 4.2.0.241 or later.

Configuration Missing Posture Checks Access granted to unmanaged or "jailbroken" devices without health checks. Malware entry from infected personal devices. Mandatory Posture Profiles (e.g., check for AV, Disk Encryption, Certs).

List of teammates

S.No	Name	College	Phone Number
1.	Arjun	Cheran Arts Science College	8098095504
2.	Aththin Ameena	Cheran Arts Science College	9943555587
3.	Pavithra	Cheran Arts Science College	7339291464
4.	Thanushree.v	Cheran Arts Science College	9150840374
5.	Srimathi	Cheran Arts Science College	7200602949

REPORT:

1. **Software & Component Vulnerabilities**

These vulnerabilities affect the technical components of the ZPA ecosystem, such as the Client Connector (ZCC) or the ZPA Cloud Service.

OS Command Injection in Client Connector

- Vulnerability/CVE: CVE-2024-23483
- CWE Category: CWE-78 (OS Command Injection)
- Description: An improper input validation flaw in the Zscaler Client Connector for macOS allows an attacker to inject and execute arbitrary OS commands. This occurs when the application processes specifically crafted inputs without adequate sanitization.
- Business Impact: Critical. Attackers can gain full control over the user's endpoint. Since the ZCC is the "gateway" to private applications, a compromised agent can be used to bypass security controls and intercept sensitive corporate data.

Authentication Bypass via Signature Flaw

- Vulnerability/CVE: CVE-2025-54982
- CWE Category: CWE-347 (Improper Verification of Cryptographic Signature)
- Description: A server-side vulnerability in Zscaler's SAML authentication mechanism where cryptographic signatures were not properly verified.
- Business Impact: Critical. This could allow an attacker to forge authentication tokens and assume the identity of any user. In an application-specific policy environment, this grants unauthorized access to sensitive internal segments like production databases or HR portals.

Local Privilege Escalation (Mac)

- Vulnerability/CVE: CVE-2024-31127
- CWE Category: CWE-346 (Origin Validation Error)
- Description: Improper verification of loaded libraries in ZCC (macOS) allows a local user with low privileges to load a malicious library and execute code with elevated (root) permissions.
- Business Impact: High. Enables an internal threat or a compromised user to bypass local security software, harvest credentials from memory, and manipulate ZPA configuration to gain broader access than intended.

2. Configuration & Logical Vulnerabilities

These risks arise from how policies are implemented. Even with a "perfect" software version, poor policy design leads to security failure.

Broken Access Control (Implicit Allow)

- OWASP Category: A01:2021 – Broken Access Control
- SANS Category: CWE-285 (Improper Authorization)
- Description: Defining applications using broad subnets (e.g., 10.0.0.0/8) instead of specific FQDNs. This recreates a "flat network" within a Zero Trust tool.

- Business Impact: High. This negates the primary benefit of ZPA. If a single application in that subnet is compromised, the attacker can move laterally to any other server in the same range, leading to widespread data breaches or ransomware.

Security Misconfiguration (Policy Shadowing)

- OWASP Category: A05:2021 – Security Misconfiguration
- SANS Category: CWE-1025 (Comparison of Incorrect Values)
- Description: ZPA uses a "First Match" logic. A common error is placing a broad "Allow" rule at the top of the list (e.g., "Allow All Employees to All Web Apps") which "shadows" a more specific "Deny" rule for sensitive apps further down.
- Business Impact: High. Specific security restrictions (like blocking contractors from the Finance app) are never evaluated, granting unauthorized access due to administrative oversight.

Failure to Enforce Device Posture

- OWASP Category: A07:2021 – Identification and Authentication Failures
- SANS Category: CWE-290 (Authentication Bypass by Spoofing)
- Description: Allowing access based solely on identity (username/password) without validating the health of the device (disk encryption, firewall status, or presence of corporate certificates).
- Business Impact: Medium. Infected personal devices or "jailbroken" machines can connect to the core infrastructure, acting as a bridge for malware to enter the private application environment.

3. Infrastructure & Resilience Vulnerabilities

App Connector Exposure

- OWASP Category: A04:2021 – Insecure Design

- Description: Placing ZPA App Connectors in a DMZ with inbound ports (TCP 443/80) open to the internet.
- Business Impact: Critical. ZPA is designed for "inside-out" connectivity (outbound only). Opening inbound ports creates a discoverable attack surface, making the connector vulnerable to DDoS attacks or direct exploitation, which defeats the "Invisibility" pillar of Zero Trust.

STAGE 2

In this stage of the project, the main focus is understanding how application-specific access policies work using Zscaler Private Access. ZPA is part of the Zero Trust Network Access architecture which follows the principle “Never Trust, Always Verify.”

Traditional VPN solutions allow users to connect directly to the internal network, which may expose many internal resources to attackers. If an attacker compromises a user account or device, they may move laterally across the network and access sensitive data. ZTNA solves this problem by providing secure application-level access instead of network-level access.

Using ZPA, administrators can create application-specific access policies. These policies ensure that users can access only the applications they are authorized to use. For example, students may access only the Learning Management System (LMS), faculty members may access the ERP portal, and IT administrators may access internal management servers. This method reduces the attack surface and improves overall network security.

ZPA verifies the identity of the user and the security posture of the device before allowing access. Once the user is authenticated, ZPA creates a secure micro-tunnel

between the user and the requested application. The internal network remains hidden, and users cannot see or scan other resources.

During this stage, vulnerability assessment was also performed using Nessus. Nessus is a widely used security scanning tool that helps identify vulnerabilities in websites, servers, and network devices. It scans the target system and detects security weaknesses such as outdated software, weak encryption protocols, and misconfigured services.

By using Nessus, security teams can identify potential vulnerabilities before attackers exploit them. The scan results include the vulnerability name, severity level, plugin ID, description, and recommended solution.

This stage helped in understanding both secure application access through ZTNA and vulnerability assessment using Nessus, which are important components of modern cybersecurity

What I Understood About Nessus

Nessus is a vulnerability assessment tool used to scan networks, systems, and applications for security weaknesses. It works by checking thousands of known vulnerabilities using plugins and security databases.

Nessus provides detailed reports that include:

Vulnerability name

Severity level (Low, Medium, High, Critical)

Plugin ID

Description of the issue

Recommended solution

This tool helps organizations identify risks early and fix security issues before they can be exploited by attackers.

Target Website

http://dvwa.co.uk

Target IP Address

192.168.1.10

List of Vulnerabilities:

S.No	Vulnerability Name	Severity	Plugin
1.	SSL Certificate Cannot Be Trusted	Medium	51192
2.	TLS 1.0 Protocol Enabled	Medium	104743
3.	HTTP Methods Allowed	Low	11213
4.	Missing Security Headers	Medium	11219

REPORT:

Vulnerability Name

SSL Certificate Cannot Be Trusted

Severity: Medium

Plugin: 51192

Port: 443

Description:

This vulnerability occurs when the SSL certificate of a website is not issued by a trusted certificate authority. As a result, users may receive a warning when accessing the site.

Solution:

Install a valid SSL certificate issued by a trusted certificate authority.

Business Impact:

Attackers may exploit this issue to perform man-in-the-middle attacks and intercept sensitive data.

Vulnerability Name

TLS 1.0 Protocol Enabled

Severity: Medium

Plugin: 104743

Port: 443

Description:

The server supports an outdated encryption protocol (TLS 1.0), which is considered insecure and vulnerable to cryptographic attacks.

Solution:

Disable TLS 1.0 and enable stronger protocols such as TLS 1.2 or TLS 1.3.

Business Impact:

Sensitive data may be exposed if attackers exploit weak encryption protocols.

Vulnerability Name

HTTP Methods Allowed

Severity: Low

Plugin: 11213

Port: 80

Description:

The web server allows unnecessary HTTP methods such as PUT or DELETE that may be misused by attackers.

Solution:

Restrict HTTP methods to only required ones such as GET and POST.

Business Impact:

Attackers could manipulate server resources if unnecessary HTTP methods are enabled.

Vulnerability Name

Missing Security Headers

Severity: Medium

Plugin: 11219

Port: 80

Description:

The web application does not implement important HTTP security headers such as Content-Security-Policy and X-Frame-Options.

Solution:

Configure proper security headers in the web server configuration.

Business Impact:

This may expose the website to attacks such as clickjacking or cross-site scripting.

Vulnerability Name

Open Port Detected

Severity: Low

Plugin: 10335

Port: 22

Description:

An open port was detected on the system, which may expose services that could be targeted by attackers.

Solution:

Close unnecessary ports or restrict access using firewall rules.

Business Impact:

Open ports increase the attack surface of the system and may allow unauthorized access.

STAGE 3

REPORT:

Title: Application Specific Access Policies using Zscaler Private Access (ZPA)

SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized team responsible for monitoring, detecting, and responding to cybersecurity threats in an organization. The main goal of SOC is to protect network infrastructure, applications, and sensitive data from cyber attacks. SOC analysts continuously monitor logs, alerts, and network activities using security tools. In the context of this project, SOC plays an important role in monitoring user access and security events when implementing application-specific access policies through Zscaler Private Access. When suspicious activities such as unauthorized login attempts or unusual network traffic are detected, SOC analysts investigate the issue and take necessary actions to prevent security breaches. Through this concept, I understood how organizations maintain security monitoring and protect their systems 24/7.

SOC Cycle

The SOC cycle refers to the structured process followed by the security operations team to handle cyber threats effectively. The SOC cycle typically includes several stages such as monitoring, detection, analysis, response, and reporting. In the monitoring phase, security tools collect logs and network data. During the detection phase, alerts are generated when abnormal activity is identified. In the analysis stage, SOC analysts investigate the alert to determine whether it is a real threat or a false positive. If the threat is confirmed, the response phase begins where appropriate security actions are taken such as blocking IP addresses, isolating systems, or updating security policies. Finally, the reporting stage documents the incident and helps improve future security strategies. Understanding the SOC cycle helped me learn how organizations manage cybersecurity incidents systematically.

SIEM

Security Information and Event Management (SIEM) is a technology used to collect, analyze, and monitor security data from various sources such as servers, firewalls, network devices, and applications. SIEM systems help security teams detect potential threats by correlating data from multiple sources. In modern cybersecurity environments, SIEM tools are essential for real-time monitoring and threat detection. One commonly used SIEM tool is IBM QRadar, which collects logs and analyzes them to identify suspicious activities. Through this concept, I understood how SIEM systems help organizations detect cyber attacks quickly and respond to them efficiently. SIEM also supports compliance reporting and security audits.

SIEM Cycle

The SIEM cycle describes how SIEM systems process and analyze security data. The cycle begins with data collection, where logs and events are gathered from different systems and devices. Next is data normalization, where the collected data is converted into a standard format so that it can be easily analyzed. After normalization, correlation and analysis are performed to identify patterns or anomalies that may indicate a security threat. When a suspicious activity is detected, the system generates an alert for the security team. Finally, incident

response and reporting are carried out to mitigate the threat and document the event. Understanding the SIEM cycle helped me learn how security teams use technology to detect threats and maintain network security.

MISP (Threat Intelligence Platform)

MISP is an open-source threat intelligence platform used for sharing and analyzing cybersecurity information. It helps organizations collect data about cyber threats such as malicious IP addresses, malware signatures, and attack techniques. By sharing this information with other organizations and security teams, MISP helps improve threat detection and prevention. In the context of SOC and SIEM, MISP provides valuable threat intelligence that can be integrated into security monitoring systems. This allows SOC teams to detect known threats more quickly and take proactive security measures. Learning about MISP helped me understand how threat intelligence plays a critical role in modern cybersecurity operations.

Your College Network Information

A typical college network consists of multiple components such as student computer labs, administrative offices, faculty systems, servers, and internet connectivity infrastructure. The network usually includes routers, switches, wireless access points, firewalls, and servers that host important applications like the Learning Management System (LMS), student information system, and ERP portals. Students and faculty access these systems using computers, laptops, or mobile devices connected to the campus network.

To improve security in such an environment, Zero Trust Network Access solutions like Zscaler Private Access can be implemented. With ZPA, users are granted access only to specific applications rather than the entire network. For example, students can access only academic portals, while faculty members can access administrative systems. This approach ensures that sensitive systems remain protected from unauthorized access and reduces the risk of cyber attacks within the college network.

How You Think You Deploy SOC in Your College

To deploy a Security Operations Center (SOC) in our college, the first step is to identify all critical assets in the network such as servers, student portals, administrative systems, and laboratory computers. Security monitoring tools should be installed to collect logs from these devices. A centralized monitoring system can then analyze these logs and detect suspicious activities.

Using Zscaler Private Access, the college can implement application-specific access policies so that users can access only the applications required for their role. For example, students can access the learning management system while administrative staff can access internal management systems.

The SOC team in the college would continuously monitor network activity, identify threats, and respond quickly to any suspicious events. Proper training should also be provided to IT staff so they can manage security incidents effectively and maintain the overall security of the campus network.

Threat Intelligence

Threat intelligence refers to the process of collecting and analyzing information about potential cyber threats. This information may include malicious IP addresses, malware signatures, phishing attacks, or vulnerabilities that attackers commonly exploit. By understanding these threats, organizations can take proactive measures to protect their systems.

Threat intelligence platforms such as MISP allow security teams to share information about cyber attacks and new vulnerabilities. This helps organizations stay updated with the latest security risks.

In the context of this project, threat intelligence can be integrated with network monitoring systems and access control policies. This ensures that suspicious traffic or malicious users are identified early and blocked before they cause damage to the system.

Incident Response

Incident response is the process of identifying, managing, and resolving cybersecurity incidents such as malware infections, unauthorized access attempts, or data breaches. The main goal of incident response is to reduce damage and restore normal operations as quickly as possible.

The incident response process usually involves several steps: detection, analysis, containment, eradication, and recovery. First, the SOC detects suspicious activity through monitoring tools. Then security analysts investigate the issue to determine the cause of the incident. After identifying the threat, the affected systems are isolated to prevent further damage. Finally, the issue is resolved and the system is restored to normal operation.

Proper incident response procedures help organizations respond quickly to cyber attacks and improve their overall cybersecurity posture.

QRadar & Understanding About the Tool

IBM QRadar is a powerful Security Information and Event Management (SIEM) tool used by organizations to monitor network security and detect cyber threats. QRadar collects log data from different sources such as servers, firewalls, applications, and network devices. It then analyzes this data to identify suspicious patterns or abnormal activities.

One of the main advantages of QRadar is its ability to correlate events from multiple sources and generate alerts when a potential security threat is detected. Security analysts can view these alerts through a centralized dashboard and investigate the issue further.

Through this project, I understood that QRadar helps organizations improve security visibility, detect cyber attacks faster, and respond to incidents more effectively. It plays a critical role in modern SOC environments by providing real-time monitoring and threat analysis.

Conclusion

Stage 1 – Web Application Testing:

From web application testing, I understood how websites can have security vulnerabilities and how attackers may exploit these weaknesses. I learned the importance of identifying security issues such as misconfigurations, insecure authentication, and outdated software to protect web applications from cyber attacks.

Stage 2 – Nessus Report:

From the vulnerability assessment using Nessus, I learned how to scan systems and identify security vulnerabilities. The Nessus report helped me understand the severity levels of vulnerabilities, their impact, and the recommended solutions to fix them.

Stage 3 – SOC / SIEM / QRadar Dashboard:

From this stage, I understood how security monitoring works in real-time using SOC and SIEM tools such as IBM QRadar. The dashboard helps security teams detect suspicious activities, analyze security events, and respond quickly to cyber threats to protect the network and applications.

Future Scope

Stage 1 – Future Scope of Web Application Testing

Web application testing will continue to evolve as web technologies become more advanced. In the future, organizations will focus more on automated security testing and continuous security assessment during the software development lifecycle. Developers will integrate security testing directly into development pipelines so that vulnerabilities can be detected and fixed early. Artificial intelligence and machine learning will also help identify complex vulnerabilities and unusual patterns in web applications. This will help organizations build more secure web applications and protect user data from cyber attacks.

Stage 2 – Future Scope of Testing Process

The vulnerability testing process will improve with more advanced scanning tools and automation techniques. Regular vulnerability assessments will become an important part of cybersecurity strategies in organizations. Security tools such as Nessus will continue to provide detailed insights about security weaknesses in systems and networks. In the future, vulnerability scanners may integrate with patch management systems to automatically fix detected vulnerabilities. Continuous monitoring and automated reporting will also help security teams respond faster to new threats and maintain a secure environment.

Stage 3 – Future Scope of SOC / SIEM

Security Operations Centers and SIEM systems will become more powerful with the integration of advanced technologies such as artificial intelligence, behavioral analytics, and automation. Modern SIEM tools like IBM QRadar will be able to detect threats more accurately by analyzing large volumes of security data. Future SOC environments will rely on automated threat detection and faster incident response mechanisms. Integration with threat intelligence platforms such as MISP will allow organizations to identify emerging cyber threats and protect their networks more effectively.

Topics Explored

During this project, several important cybersecurity concepts were explored. These topics helped in understanding modern security practices used in organizations.

Web Application Security Testing

Vulnerability Assessment and Risk Analysis

Zero Trust Network Access (ZTNA) Architecture

Application-Specific Access Policies

Security Operations Center (SOC)

SOC Monitoring and Incident Handling

Security Information and Event Management (SIEM)

Threat Intelligence and Malware Analysis

Incident Response and Security Monitoring

Tools Explored

Several cybersecurity tools were studied and understood during the completion of this project. These tools play an important role in identifying vulnerabilities, monitoring security events, and protecting organizational networks.

Nessus – Used for identifying vulnerabilities in systems and web applications.

IBM QRadar – Used for monitoring security logs, detecting threats, and analyzing network events.

MISP – Used for sharing and analyzing threat intelligence information.

Zscaler Private Access – Used to implement Zero Trust Network Access and application-specific access policies.